

FORCEPOINT

Enterprise AI Standard

AI Development, Operations & Governance

Field	Value
Document ID	ENT-AI-STD-001
Version	1.1.1 (Draft)
Classification	Confidential – Internal Use Only
Status	Draft for AI Council Review
Owner	Enterprise Systems – Mathew Steele, Director
Approved By	Forcepoint AI Council (pending)
Effective Date	Pending approval
Review Cycle	Annual (or upon material AI policy change)
Applies To	All Forcepoint employees, contractors, and third-party developers building or operating AI systems on behalf of Forcepoint

1. Purpose & Scope

This standard establishes the requirements, guardrails, and responsibilities governing the development, deployment, and ongoing operation of Artificial Intelligence (AI) systems at Forcepoint. It applies to:

- Internal AI tools and assistants are used to augment employee productivity or automate internal workflows.
- AI-powered features and capabilities embedded within Forcepoint products.
- AI agents and automation systems that act autonomously or semi-autonomously on behalf of Forcepoint or its customers.

This standard operates alongside Forcepoint's governed internal AI platform (the “AI platform”), which provides the sanctioned path for routine internal AI use. The platform's reference architecture, skill model, and gateway controls are referenced throughout this standard. The current reference implementation of the platform is documented in Appendix A; variances between this standard and the implementation are tracked in Appendix B.

This standard does not cover general-purpose SaaS AI tools governed by Forcepoint's Acceptable Use Policy, unless such tools are integrated into Forcepoint systems, pipelines, or products.

Why This Standard Matters

Forcepoint operates in a security-sensitive industry. The use of AI introduces unique risks: data exposure, model bias, unpredictable agent behavior, and regulatory liability. This standard ensures AI is deployed responsibly, with clear accountability and consistent engineering discipline - while ensuring workers have a usable sanctioned alternative to ungoverned consumer AI.

2. Guiding Principles

All AI development and use at Forcepoint shall be guided by the following principles:

Responsible by Design. AI systems must be designed with safety, privacy, and human oversight as first-class requirements, not afterthoughts.

Explainability. AI outputs that influence decisions must be interpretable and auditable by appropriate stakeholders.

Data Minimization. AI systems should access and process only the data necessary for their function. No model may be trained or fine-tuned on sensitive Forcepoint or customer data without explicit authorization.

Human-in-the-Loop. Consequential AI decisions - particularly those affecting customers, employees, or security posture - must include a human review step unless formally waived through a risk acceptance process. Where confidence-based escalation is used to implement this principle, the thresholds and the escalation path are recorded in the AI Registry.

Continuous Monitoring. Deployed AI systems must be subject to ongoing performance monitoring, drift detection, and periodic re-evaluation.

Vendor Accountability. Third-party AI providers must meet Forcepoint's security, privacy, and contractual standards before integration.

Sanctioned Path Sufficiency. Forcepoint shall provide governed AI capabilities sufficient for routine work, so that compliance with this standard does not require workers to forgo AI assistance. The acceptable-use prohibitions in Section 12 are paired with this commitment: the governed alternative is part of the policy, not an afterthought.

Approved-Component Default. Where governed AI components, skills, and configurations exist, their use is the default. Use of unapproved AI components inside corporate or secure environments requires an exception under Section 13.

Authenticated Path for Governed AI. Users authenticated to Forcepoint's corporate identity provider transact with AI through governed channels only. Unauthenticated paths are restricted to public, third-party AI tools subject to the Acceptable Use Policy; corporate confidential information may not be submitted to those paths (Section 12).

3. Governance & Ownership

3.1 Forcepoint AI Council

Forcepoint shall maintain a Forcepoint AI Council (the “AI Council”) as the senior approval body for AI at Forcepoint. The AI Council is responsible for:

- Approving new AI use cases that are customer-facing, handle sensitive data, or require enterprise-level access or distribution.
- Approving the AI platform's reference architecture, the skill contract, the approved-component list (models, skills, MCP servers, gateways, connectors), and the criteria by which components are admitted to it.
- Approving the process for validation, authentication, and use of AI and agentic features, including confidence-score thresholds for human-in-the-loop escalation.
- Resolving escalated AI risk decisions and standing exceptions.
- Reviewing this standard annually and approving revisions, including the reference implementation in Appendix A and the variance register in Appendix B.
- Ensuring alignment between AI investments, the platform roadmap, and enterprise risk appetite.

The AI Council includes representation from Enterprise Systems, IT Security, Legal/Compliance, the CIO's office, and the engineering organizations that build AI-powered products (including RD&P) so that internal-platform and product-feature concerns are both represented.

3.2 RACI Model

Activity	Enterprise Systems	Engineering / Product	IT Security	Legal & Compliance	Business Owner
AI use case intake & triage	A/R	C	C	C	R
Reference architecture & platform changes	A/R	C	C	C	I
Skill contract & registry governance	A/R	R	C	C	I
Connector layer governance & data-access policy	A/R	C	C	C	I
Per-system architecture review (exception path)	A/R	R	C	I	I

Activity	Enterprise Systems	Engineering / Product	IT Security	Legal & Compliance	Business Owner
Data privacy impact assessment	C	C	C	A/R	I
Security review & pen test	C	C	A/R	I	I
Model deployment approval (internal)	A	R	C	C	I
Model deployment approval (product)	C	A/R	C	C	I
Production monitoring & alerting	R	R	C	I	I
Vendor AI risk assessment	A/R	I	C	C	C
Incident response (AI-related)	A	R	R	C	I
Annual standard review (incl. appendices)	A/R	C	C	C	I

R = Responsible • A = Accountable • C = Consulted • I = Informed

4. AI Platform Architecture

Forcepoint maintains a governed internal AI platform that provides the default path for internal AI use. The platform is the reference architecture against which internal AI systems are designed, reviewed, and operated. This section describes the platform's structural elements in capability terms; the current concrete implementation is in Appendix A. Downstream sections reference these elements as required controls.

4.1 Default Posture: Build on the Platform

The default expectation for any new internal AI capability is delivered as a skill or composition of skills on the governed platform, not as a standalone integration. Building outside the platform is permitted only through the exception path in Section 13 and requires per-system architecture review under Section 8.

This represents a deliberate shift from the prior posture, which reviewed each AI system on its own merits. Under this standard, platform decisions (identity, network access, model gateway,

connector layer, DLP, observability) are made once and inherited; teams focus their design effort on the skills and user experience that are specific to their domain.

4.2 Platform Planes

The platform is organized in six logical planes. Each plane has a defined responsibility and a single authoritative owner. Planes communicate through documented contracts rather than shared infrastructure.

Identity planes. Workforce SSO, MFA, group-based entitlement, and SCIM provisioning. Anchored in the corporate identity provider; no local accounts on any AI platform component. The identity plane is the authoritative boundary between governed AI use (in-auth) and the public, ungoverned AI surface (out-of-auth, subject to Acceptable Use).

Network & access plane. Zero-trust network access for users reaching AI services; secure web gateway for egress; content inspection (DLP) on prompts, completions, retrieved context, and uploads. Skill-author and intake tooling (the AI Skills Portal) is reachable only over the corporate VPN.

Model plane. A model gateway that exposes a single API surface across approved foundation models, with routing, fallbacks, per-team budgets and rate limits, key rotation, and structured logging. The gateway is the only sanctioned egress point for model traffic from internal AI systems. The model plane may include multi-model deliberation or voting patterns for confidence-sensitive use cases; such patterns are themselves governed components subject to AI Council approval.

Orchestration plane. Agent orchestration runtimes that compose skills against a user task, including reasoning loops, confidence scoring, and human-in-the-loop escalation. The orchestration plane emits structured traces to the observability plane and routes all model traffic through the model gateway and all data access through the connector layer.

Skill plane. A curated, signed registry of skills (tools and integrations the model can invoke). Each skill declares its data scope, required entitlements, sensitivity tier, and Trust Tier (Section 5.2). Skill runtimes execute against source systems with the least-privilege identity that works. Two skill execution patterns are distinguished: (a) connector skills, which read and write through the connector layer to enterprise systems of record under centralized data-access policy; and (b) agentic automation, which executes workflow logic in a sandboxed, governed automation runtime separate from the connector layer (Section 9.3).

Data plane. Source systems of record (CRM, productivity suite, engineering and support systems, virtualized data sources). Accessed only through the connector layer, with per-user delegated tokens where possible. The connector layer is the single governed point of data access for AI systems; direct skill-to-source-system integration is prohibited without an exception (Section 13).

4.3 Required Platform Controls

All internal AI systems built on the platform inherit the following controls. Internal AI systems built outside the platform under exception must demonstrate equivalent controls during their per-system architecture review.

- All model traffic routes through the approved model gateway; direct integrations with model providers are prohibited for internal use without exception (Section 7.2).
- All user-to-platform traffic traverses zero-trust network access with device posture and identity checks. Authenticated corporate identities transact with governed AI; unauthenticated paths are restricted to public AI tools subject to the Acceptable Use Policy.
- All access to enterprise data sources from AI systems is mediated by the governed connector layer; the connector layer enforces a single, centrally-maintained data-access policy across source systems.
- Content inspection (DLP) is applied at four inspection points: user-to-gateway, gateway-to-model, model-to-gateway, and skill-to-gateway. Tier 2+ systems must surface inspection verdicts in their audit trail.
- Agent orchestration runtimes emit confidence scores for completions that drive consequential actions. Use cases must declare a confidence threshold below which the orchestrator escalates to a human; thresholds are recorded in the AI Registry and reviewed at intake. Default thresholds are set by the AI Council; use cases may tighten but not loosen them without exception.
- Agentic automation runtimes execute in a sandboxed environment with no direct access to production data sources; their interactions with enterprise data flow through the connector layer or through scoped skills.
- Every request carries a single correlation identifier through gateway, orchestrator, skills, connector layer, and source systems, so an incident can be reconstructed end-to-end from one pivot.
- Every model, skill, connector, agent, and user can be disabled at the gateway or connector layer without redeploying code (“kill switch”).

Platform Owner

The AI platform is operated under the CIO organization. The specific operating team and budget owner are designated by the AI Council and recorded in the AI Registry. References to “the platform” elsewhere in this standard mean the platform so designated. The current reference implementation, including the specific products providing each plane, is documented in Appendix A.

5. AI Risk & Trust Tiering

This standard uses two orthogonal tiering axes. Every AI use case is assigned an Exposure Tier; every skill (or skill-equivalent component) operating within a use case is assigned a Trust Tier. The required controls for a use case are the union of the controls implied by both axes.

5.1 Exposure Tier (use case)

The Exposure Tier reflects who sees the system's output and what regulatory scope it falls under. It is assigned at intake (Section 6) and determines the depth of review before deployment.

Tier	Definition	Examples	Required Controls
Tier 1 - Low	Internal productivity tools; no sensitive data; human reviews all outputs.	Drafting assistance, internal summarization, code suggestions.	Standard security review; manager acknowledgment.
Tier 2 - Moderate	Processes internal sensitive data or influences internal decisions; limited automation.	AI-assisted workflow routing, internal data analytics, HR tooling.	DPIA; review against platform reference architecture; Enterprise Systems approval; 90-day post-launch review.
Tier 3 - High	Customer-facing; processes customer data; autonomous actions; regulatory scope.	Customer-facing AI features, autonomous agents, and AI security products.	Full AI Council approval; security pen test; legal review; continuous monitoring; annual re-certification.

5.2 Trust Tier (skill)

The Trust Tier reflects what a skill does to data - read or write, narrow or broad, low- or high-sensitivity. It is assigned during skill registration and governs the controls applied to that skill regardless of which use case composes it.

Trust Tier	Description	Example	Controls
T1 - Read, low sensitivity	Public or internal-only data, read-only, no PII.	Search public knowledge bases; summarize a public product page.	Standard SSO; basic content inspection.
T2 - Read, confidential	Internal confidential data, read-only.	Summarize an account from CRM data; search internal documentation.	Group-based entitlement; DLP on results; per-user delegated tokens where possible.

Trust Tier	Description	Example	Controls
T3 - Write, scoped	Writes to the user's own scope or an approved shared scope.	Post to a named chat channel; create a ticket in a named project.	Step-up MFA; explicit user confirmation per call; narrow service scopes; full audit.
T4 - Write, broad / external	Writes that affect many users or leave the tenant.	Send external email on user's behalf; bulk-update records.	AI Council approval per skill; time-boxed entitlement; dual-control review of usage.

5.3 Combining the Axes

A use case's required controls are the union of the controls implied by its Exposure Tier and the highest Trust Tier of any skill it composes. A Tier 2 use case that composes a T4 skill is governed by the stricter of the two for any given control.

Compositions that pair high-exposure use cases with high-trust skills receive additional scrutiny:

- Exposure Tier 3 use cases may only compose T1 or T2 skills by default; composing a T3 or T4 skill requires explicit AI Council approval of the composition, not just the individual skill.
- Any composition of a T4 skill, at any Exposure Tier, requires AI Council approval and time-boxed entitlement, with re-approval at expiry.

6. AI Use Case Intake & Approval

All net-new AI capabilities - whether built internally on the platform, integrated via API, or procured as a vendor product - must be submitted through the AI Use Case Intake process before development or deployment begins. Existing components in use prior to this standard must be validated through the same process on a schedule set by the AI Council.

6.1 Intake Trigger Criteria

The intake process is required when any of the following apply:

- The capability uses generative AI, LLMs, or foundation models.
- The system will process Forcepoint confidential data, employee PII, or customer data.
- The system will produce outputs that influence business decisions (pricing, hiring, security posture, etc.).
- The system will act as an autonomous or semi-autonomous agent.
- The capability will be exposed to external users (customers, partners).

- The capability will be built or operated outside the governed AI platform (this is an exception path; see Section 13).

6.2 Intake Process

- Submitter completes the AI Use Case Intake Form, available through the AI Skills Portal under Enterprise Systems / AI Governance. The Portal is reachable only over the corporate VPN and is the authoritative front door for both new use cases and skill authoring.
- Submission triggers a tracked work item in the engineering issue-tracker for triage and review; the work item is the system of record for the intake.
- Enterprise Systems performs initial triage within 5 business days, including assignment of an Exposure Tier, identification of the Trust Tiers of any skills the use case will compose, and confirmation of the required confidence-escalation threshold (Section 4.3).
- Tier 2 use cases are reviewed by Enterprise Systems and IT Security against the platform reference architecture.
- Tier 3 use cases, any use case involving a T4 skill, and any use case requesting an out-of-platform exception, are routed to the AI Council for approval.
- Approved use cases are logged in the Forcepoint AI Registry, with their Exposure Tier, the Trust Tiers of composed skills, the platform vs. exception path, the confidence-escalation threshold, and the assigned reviewer of record.

AI Registry

Enterprise Systems maintains a centralized AI Registry documenting all approved AI systems, their owners, data classifications, exposure and trust tiers, platform/exception path, confidence thresholds, and review dates. The registry is reviewed quarterly by the AI Council and published internally via Confluence.

7. Data Privacy & Security

7.1 Data Classification Requirements

AI systems must respect Forcepoint's Data Classification Policy. The following restrictions apply:

Data Classification	May Be Used for Inference?	May Be Used for Fine-tuning / Training?	Additional Requirements
Public	Yes	Yes (with approval)	None.
Internal	Yes	Yes, with Tier 2 approval	Log data access; review retention.

Data Classification	May Be Used for Inference?	May Be Used for Fine-tuning / Training?	Additional Requirements
Confidential	Limited - see policy	No, without explicit CISO sign-off	DPIA required; encryption in transit and at rest.
Restricted / Customer PII	No, without legal review	Never	Legal and DPO approval required; contractual review.

7.2 Model Provider Access - Internal AI Systems

Internal AI systems access foundation models through the approved AI platform model gateway. Direct integration with third-party model providers from internal AI systems is not permitted without an exception under Section 13.

The model gateway centrally enforces; on behalf of all internal systems it serves:

- A reviewed and executed Data Processing Agreement with each model provider.
- Zero-retention or contractually-equivalent terms (data submitted to providers is not used for their model training).
- Provider compliance with Forcepoint's vendor security requirements (SOC 2 Type II or equivalent).
- Storage of API keys and credentials in an approved secrets manager, never in source code or configuration files.
- Documented rate limits, quotas, budgets, and failover behaviors per team and per skill.

Teams building internal AI systems on the platform inherit these controls and do not re-perform the per-provider review for each integration. Teams must, however, confirm that any specific model they intend to use is on the approved-model list maintained by the AI Council.

7.3 Enterprise Data Access - Connector Layer

AI systems access enterprise data sources only through the governed connector layer. The connector layer is the single, centrally-administered point of policy enforcement for data access from AI systems and enforces, on behalf of all skills and orchestrators it serves:

- Per-user delegated authentication to the source system where supported, or a service identity scoped to the minimum required permission set where not.
- A central data-access policy applied uniformly across source systems, including field-level redaction for sensitive attributes.
- Structured access logging with the platform correlation identifier (Section 4.3).
- Rate limiting and quota enforcement at the source-system level to protect operational integrity of systems of record.

Direct skill-to-source-system integration that bypasses the connector layer is prohibited without an exception under Section 13. The set of source systems available through the connector layer, and their data-classification mappings, are maintained by Enterprise Systems with the relevant data stewards and published in the AI Registry.

7.4 Model Provider Access - Product Features

AI-powered features embedded within Forcepoint products operate under different constraints than internal AI systems: customer data residency, customer-chosen models, latency budgets, and contractual obligations differ materially. Product teams are therefore subject to a parallel - not identical - set of model-provider requirements.

Product teams shipping AI-powered features must:

- Use providers and models from the AI Council's Approved AI Vendor List (Section 11). Use of a non-listed provider requires an exception under Section 13.
- Confirm directly - not by inheritance - that the items in Section 7.2 (DPA, zero-retention, SOC 2, secrets management, rate limits) are in place for the product's integration.
- Submit the product's architecture for per-system review under Section 8, including identification of how the controls equivalent to the platform's Section 4.3 controls are implemented in the product.
- Operate a product-scoped gateway where scale, customer requirements, or architecture warrant it; such gateways are subject to AI Council review on a schedule the Council sets.

Product teams do not route through the internal AI platform's gateway. The two paths are intentionally separated so that customer obligations and worker-platform decisions can evolve independently.

7.5 Prompt & Output Security

- All AI interfaces exposed to users must implement input validation and prompt injection mitigations.
- Outputs from AI systems must not be passed directly to command execution, database queries, or external APIs without sanitization.
- Systems handling confidential data must implement output filtering to prevent inadvertent disclosure.
- Content inspection (DLP) at the four platform inspection points (Section 4.3) is the required implementation for internal AI systems on the platform. Out-of-platform and product systems must implement equivalent inspection coverage and document it in their architecture review.
- Audit logs must capture user inputs and AI outputs for Tier 2 and Tier 3 systems, with retention per the Records Retention Schedule.

8. AI Development Standards

8.1 Architecture & Design

Architecture review is conducted on two paths:

- **Platform path (default).** Internal AI systems delivered as skills on the governed platform inherit the platform's reference architecture. Architecture review for these systems is conducted as a skill contract review under Section 9.2 - the team specifies what the skill does, what data it touches, and what side effects it has, and the review focuses on those specifics rather than re-reviewing platform decisions.
- **Exception path (per-system).** Internal AI systems built outside the platform, and all product features with embedded AI, undergo per-system architecture review. The review confirms the system has equivalent controls to the platform's Section 4.3 controls, documents failure modes and fallback behaviors, and assesses scope-limiting controls for any agentic behavior. Per-system review must be completed prior to development start.

All AI systems - platform or exception path - must:

- Define explicit failure modes and fallback behaviors (graceful degradation).
- Implement scope-limiting controls for agentic behavior: agents may only access resources explicitly granted for their defined purpose.
- Expose health-check and observability endpoints consumable by Forcepoint's monitoring stack.
- Be built with feature-flag controls enabling rapid disablement without a full deployment.

8.2 Model Selection & Evaluation

Before selecting a foundation model or AI service, teams must document:

- Model capabilities and known limitations relevant to the use case.
- Benchmark results on representative Forcepoint data samples (where feasible).
- Bias and fairness evaluation (required for Tier 2+).
- Cost model and projected inference volume.
- Vendor lock-in risk and mitigation strategy. For platform-path systems, lock-in risk is mitigated by the gateway abstraction; this control should be referenced rather than re-engineered.

8.3 Prompt Engineering Standards

- System prompts must be version-controlled in the same repository as the application code.
- Prompts must include explicit instructions for handling out-of-scope requests, confidential data, and refusals.
- Prompt changes that materially affect system behavior are subject to the same change management process as code changes.

- Prompts must not instruct the model to override safety behaviors or misrepresent the system's nature to users.
- Retrieved content (RAG context, tool results) must be treated as data, not as instructions; prompts must be structured to resist prompt injection from retrieved content.

8.4 Testing Requirements

- Unit and integration tests must cover AI response parsing, error handling, and timeout scenarios.
- Adversarial testing (prompt injection, jailbreak attempts) is required for Tier 2+ systems before production deployment.
- Regression suites must include golden-set evaluations to detect model drift following provider updates.
- Load testing must validate system behavior under peak concurrency before go-live.

8.5 Code & Repository Standards

- AI-specific dependencies and model client versions must be pinned; floating versions are prohibited.
- Model configurations (temperature, max tokens, top-p, etc.) must be externalized as environment variables or configuration files, not hardcoded.
- All AI integrations must implement retry logic with exponential backoff and circuit breakers. Platform-path systems inherit these behaviors from the gateway and need not re-implement them.
- Repositories containing AI system code must have a documented README covering: purpose, data flow, model providers used (or gateway routing references), composed skills, connector-layer data sources, and operational runbook location.

9. AI Agents, Skills & Autonomous Automation

AI agents - systems capable of taking actions, calling tools, or executing multi-step plans with limited human supervision - introduce elevated risk and are subject to additional requirements. Under this standard, agentic behavior is expressed as compositions of registered skills rather than ad-hoc integrations; the skill registry and skill contract are the primary governance mechanism for agents.

9.1 Agent Design Principles

- Minimal footprint: agents must request only the permissions needed for their defined task and release them when done.
- Explicit action boundaries: every agent must have a documented list of permitted and prohibited actions, expressed as the set of skills it is entitled to compose.

- Interrupt and override: all agents must support a documented kill-switch mechanism that halts execution without data loss. On the platform, this is implemented at the gateway and at the connector layer.
- Confidence-driven escalation: agents must emit a confidence score for any action with material consequence and escalate to a human reviewer when confidence is below the threshold declared in the use case's Registry entry. Thresholds are set per use case; the AI Council publishes default thresholds for routine and high-risk classes.
- Confirmation gates: actions with irreversible effects (deletion, external communication, financial transactions) must prompt for human confirmation unless explicitly approved for autonomous execution through a risk acceptance. Skill Trust Tiers T3 and T4 inherit this requirement by default.
- Sandboxed development and staging: agent testing must occur in isolated environments with no access to production systems or real customer data.

9.2 Skill Contract

Every skill registered for use by an agent or AI system must declare, in a signed manifest reviewed by the AI Council or its delegate:

- Name, version, description, and the tool schema the model sees.
- Data sources accessed, with specific scopes, and whether access is via the connector layer or via an exception.
- Side-effect classification: read-only, write-to-user, write-to-shared, or write-to-external.
- Sensitivity tier of data the skill can touch (public, internal, confidential, restricted).
- Trust Tier (T1–T4 per Section 5.2).
- Required entitlement groups for invocation.
- Inputs and outputs expressed as schemas the platform can validate.
- Rate and quota limits, per user and per skill.

Skill contracts are immutable per version. Changing a skill's scope, side effects, or sensitivity tier requires a new version and a new review. Skill authors cannot grant entitlements; entitlement groups are owned by the data steward of the source system.

9.3 Connector Skills vs. Agentic Automation

The skill plane distinguishes two execution patterns; both are governed but operate under different runtime assumptions, and a skill is registered as one or the other:

- **Connector skills.** Skills whose primary effect is reading or writing data in enterprise systems of record. All such skills execute via the governed connector layer (Section 7.3); the connector layer is the single point of data-access policy enforcement. Connector skills are the default for data-bearing operations.
- **Agentic automation.** Skills whose primary effect is the execution of workflow logic - sequences, branching, scheduled actions, security orchestration - and whose data

interactions are limited to the connector layer or to scoped APIs. Agentic automation runs in a sandboxed, governed automation runtime separate from the connector layer, with its own resource and identity boundaries. Agentic automation is the default for workflow logic; it is not a substitute for connector skills when the operation is fundamentally a data read or write.

Both patterns are subject to the skill contract (Section 9.2), the Trust Tier framework (Section 5.2), and the skill lifecycle (Section 9.4). Agentic automation runtimes require an additional review by IT Security at registration to confirm the sandbox configuration and the absence of unscoped data-source access.

9.4 Skill Lifecycle

- **Propose:** a team proposes a skill via the AI Skills Portal, including the contract metadata, a data-handling justification, and the pattern declaration (connector skill or agentic automation).
- **Review:** security, privacy, and a domain data steward review. T3 and T4 skills, and all agentic-automation skills, receive AI Council review.
- **Build and sign:** the skill runtime is built, its manifest is signed, and it is deployed to the skill runtime environment owned by the publishing team.
- **Register:** the manifest is published to the central skills registry; entitlement groups are wired up in the identity provider.
- **Pilot:** available to a named pilot group for a fixed period with elevated logging and review.
- **General availability:** after review of pilot telemetry and content-inspection events.
- **Deprecation:** skills have explicit end-of-life dates; the agent's available tool list always reflects current entitlements.

9.5 Agent Logging & Auditability

All agent executions must produce structured logs capturing:

- Task objective and triggering event.
- Each skill (tool) call made, with inputs and outputs (sensitive fields masked).
- Reasoning steps (where the model produces chain-of-thought).
- Confidence scores emitted at each decision point, and any escalations triggered.
- Final outcome and any errors encountered.
- Elapsed time and token consumption.
- Correlation identifier tying the agent's calls to gateway requests, connector-layer reads/writes, and source-system actions (Section 4.3).

Logs must be retained for a minimum of 90 days for Tier 1 agents and 1 year for Tier 2/3, consistent with Forcepoint's Records Retention Schedule.

9.6 Agent Escalation & Failure

- Agents must escalate to a human when the emitted confidence score is below the declared threshold or when an unexpected state is encountered. Escalation paths are defined per use case and recorded in the Registry.
- Failure handling must be idempotent: partial executions must not leave systems in an inconsistent state.
- All agent failures must be captured in a dedicated alert channel monitored by the owning team.

10. Production Monitoring, Telemetry & Incident Response

10.1 Operational Monitoring Requirements

All Tier 2 and Tier 3 AI systems in production must implement:

- Latency and error-rate dashboards with alerting thresholds defined pre-launch.
- Input/output logging with PII masking where applicable.
- Token consumption and cost tracking with budget alerts.
- Model performance monitoring: output quality metrics tracked against baselines established at launch.
- Drift detection: automated alerts when output distribution shifts materially from baseline.
- Confidence-score telemetry: distribution of emitted confidence scores and rate of HITL escalations, tracked against the use case's declared threshold.

10.2 Required Platform Telemetry

Internal AI systems on the platform contribute to a shared telemetry pipeline that supports the AI Council's oversight role. The following measurements are required and visible on a platform-wide dashboard with role-based views (executive, platform operations, department manager):

Measurement	Definition	Primary View
Weekly active users	Unique identities issuing at least one prompt in the week.	Executive, Manager
Skill invocations	Count of successful skill calls, excluding retries.	All
Grounded-answer ratio	Conversations with at least one skill invocation, divided by total conversations.	Executive, Manager
AI-use / skills-use gap	Conversations without any skill, divided by total conversations. Tracked as the primary platform-quality KPI.	Executive (primary KPI)
Content-inspection event rate	DLP policy hits per 1,000 interactions, by action.	Executive, Ops

Measurement	Definition	Primary View
Trust Tier mix	Share of invocations by skill Trust Tier (T1–T4).	Ops
Connector layer activity	Source-system reads and writes via the connector layer, by system and Trust Tier.	Ops
HITL escalation rate	Share of agent interactions escalated to a human under the confidence-threshold rule (Section 4.3).	Executive, Ops
Cost per successful task	Total model spend divided by successful completions, by department.	Executive, Ops
Model mix and fallback rate	Share of invocations by model and share of requests requiring a fallback.	Ops
Satisfaction	Mean user rating on completions, with sample size.	Executive, Manager

Why the AI-use / Skills-use Gap is the Primary KPI

High AI use with low skills use means workers are getting answers that are not grounded in enterprise data. That is a quality problem for the worker and a data-protection problem for the organization. The goal is not to suppress AI use; it is to narrow the gap by making skills easier to discover, faster to invoke, and broader in coverage.

The dashboard does not display prompt or completion content; content-bearing fields are reduced to counts, categories, and inspection verdicts before reaching the warehouse. The dashboard is not an individual productivity monitor; per-user metrics are not exposed to managers by design.

10.3 AI-Specific Incident Classification

Severity	Description	Response SLA	Notification
SEV-1 - Critical	AI system producing outputs causing customer harm, data exposure, or security breach.	Immediate - disable system within 1 hour.	CISO, CIO, Legal within 2 hours.
SEV-2 - High	Significant output degradation; agent acting outside defined boundaries; compliance risk.	Assess and mitigate within 4 hours.	Enterprise Systems, IT Security.
SEV-3 - Moderate	Model drift, elevated error rates, cost anomalies, sustained HITL escalation spikes.	Root cause within 24 hours.	Owning team + Enterprise Systems.
SEV-4 - Low	Minor quality degradation; non-critical latency increase.	Address in next sprint.	Owning team.

10.4 Post-Incident Review

All SEV-1 and SEV-2 AI incidents require a written Post-Incident Review (PIR) within 5 business days covering root cause, impact assessment, remediation taken, and preventive measures. PIRs are filed with Enterprise Systems and reviewed at the next AI Council meeting.

11. Third-Party AI Vendor Management

The procurement or integration of third-party AI services must follow the vendor onboarding process managed by Enterprise Systems. Prior to approval:

- Vendor must complete Forcepoint's standard Third-Party Risk Assessment.
- AI-specific addendum to the vendor questionnaire must be completed, covering model training data use, data residency, and audit rights.
- Legal must review and execute a Data Processing Agreement before any Forcepoint data is transmitted to the vendor's systems.
- Enterprise Systems must confirm the integration architecture meets this standard's security requirements, including the Section 4.3 platform controls or per-system equivalents.
- Ongoing: vendor AI systems used in Tier 2+ contexts are subject to annual re-assessment.

Approved AI Vendor List

The AI Council maintains the Approved AI Vendor List, published by Enterprise Systems in Confluence. The list distinguishes vendors approved for internal-platform use, vendors approved for product-feature use, and vendors approved for both. Teams must use listed providers wherever feasible. Use of a non-listed provider requires an exception under Section 13.

12. Acceptable Use

The acceptable-use rules in this section are paired with Forcepoint's commitment under Section 2 (Sanctioned Path Sufficiency) to provide a governed AI platform sufficient for routine work. The prohibitions exist because a sanctioned alternative exists; the sanctioned alternative exists because the prohibitions are real.

The following uses of AI are expressly prohibited without explicit written exception from the AI Council:

- Training or fine-tuning any model on Forcepoint Restricted or Customer PII data.
- Deploying AI systems that make binding legal, financial, or employment decisions without human review.

- Using AI-generated content to impersonate a Forcepoint employee, customer, or partner.
- Submitting Forcepoint confidential information to consumer-grade AI tools (e.g., free-tier chat assistants, public model UIs) where data may be used for training. The governed platform is the sanctioned alternative for this work.
- Deploying AI agents with write access to production systems without an approved risk acceptance.
- Bypassing or disabling safety guardrails built into licensed AI platforms.
- Using AI components, skills, MCP servers, connectors, or model integrations that are not on the approved-component list inside corporate or secure environments, without an exception.
- Bypassing the governed connector layer to integrate a skill or agent directly with an enterprise data source, without an exception.

Violations of this standard may result in disciplinary action up to and including termination, consistent with Forcepoint's Code of Conduct.

13. Exceptions & Waivers

Teams requiring an exception to any requirement in this standard - including building outside the platform, using a non-listed provider, bypassing the connector layer, or composing a higher-tier skill in a higher-exposure use case - must:

- Submit an Exception Request via the AI Skills Portal, clearly identifying the specific requirement, business justification, and proposed compensating controls.
- Obtain written approval from the Director of Enterprise Systems and the relevant risk owner (CISO for security controls, DPO for privacy controls). Exceptions involving T4 skills, Exposure Tier 3 systems, connector-layer bypass, or out-of-platform builds also require AI Council approval.
- Document the exception in the AI Registry with an expiry date not to exceed 12 months.
- Re-evaluate the exception at expiry; recurring exceptions should be escalated to the AI Council as a potential standard revision or platform investment.

14. Training & Awareness

- All employees using AI tools in their work must complete Forcepoint's AI Acceptable Use training (annual, 30 minutes) available via the LMS.
- Developers building AI systems must complete the AI Engineering Practices module (required at onboarding; refreshed annually). The module includes the platform reference architecture, the skill contract, the connector-layer model, the four content-inspection points, and confidence-based escalation.

- Product Managers owning AI features must complete the AI Product Risk & Governance training prior to launching any Tier 2+ feature.
- Skill authors must complete a skill-authoring module covering the skill contract, Trust Tiers, signing, the connector skill vs. agentic automation distinction, and the skill lifecycle.
- Completion is tracked by HR and reported to functional leads quarterly.

15. Definitions

Term	Definition
Agentic Automation	A skill execution pattern whose primary effect is the execution of workflow logic (sequences, branching, scheduled actions, security orchestration). Runs in a sandboxed, governed automation runtime separate from the connector layer (Section 9.3).
AI Agent	A system that uses an LLM or other AI model to autonomously plan and execute multi-step tasks, including invoking registered skills or external tools.
AI Council	Forcepoint's senior AI approval body - the Forcepoint AI Council - described in Section 3.1.
AI Platform	The governed internal AI platform described in Section 4, providing the default path for internal AI use at Forcepoint.
AI Registry	Forcepoint's centralized inventory of approved AI systems, maintained by Enterprise Systems.
AI Skills Portal	The VPN-protected portal that serves as the front door for AI Use Case Intake, skill authoring, and exception requests (Section 6.2).
Approved-Component List	The list of AI components (models, skills, MCP servers, connectors, gateways) that the AI Council has admitted for use in corporate and secure environments.
Confidence Score	A numeric value produced by an orchestrator (or model) representing the system's estimated reliability of a given output. Used to trigger human-in-the-loop escalation against a use-case-specific threshold recorded in the AI Registry.
Connector Layer	The governed component that mediates all access from AI systems to enterprise data sources. Applies a single, central data-access policy across source systems (Section 7.3).
Connector Skill	A skill whose primary effect is reading or writing data in enterprise systems of record, executed via the connector layer (Section 9.3).

Term	Definition
Content Inspection Point	One of the four locations at which DLP inspection is applied on the platform: user-to-gateway, gateway-to-model, model-to-gateway, and skill-to-gateway (Section 4.3).
DPIA	Data Protection Impact Assessment - a structured process to identify and mitigate privacy risks in data processing activities.
Exposure Tier	The use-case tiering axis (Tier 1–3) defined in Section 5.1, reflecting who sees the system's output and what regulatory scope it falls under.
Fine-tuning	The process of further training a pre-trained model on domain-specific data to improve performance on targeted tasks.
Forcepoint Flow	Forcepoint's Enterprise Architecture initiative, which includes AI-powered automation and integration capabilities across enterprise systems.
Foundation Model	A large-scale pre-trained model used as the basis for AI-powered features or applications.
HITL Escalation	Human-in-the-Loop escalation - the routing of an agent's pending action to a human reviewer when the emitted confidence score is below the use case's declared threshold.
Model Drift	Degradation in an AI model's output quality or distribution over time.
Model Gateway	The platform component that exposes a single API surface across approved foundation models and is the sole sanctioned egress point for model traffic from internal AI systems (Section 4.2).
Orchestration Plane	The platform plane that runs agent orchestration, reasoning loops, confidence scoring, and HITL escalation (Section 4.2).
Prompt Injection	An attack technique in which malicious content in the AI's input attempts to hijack its instructions or behavior.
RAG	Retrieval-Augmented Generation - a technique in which relevant documents are retrieved and provided to an LLM as context to ground its responses.
Skill	A registered, signed tool the platform exposes to AI agents and AI systems, with a declared scope, sensitivity, side-effect class, and Trust Tier.
Skill Contract	The signed manifest declaring a skill's metadata and constraints (Section 9.2).

Term	Definition
Skill Registry	The central, signed catalog of skills available on the platform.
Trust Tier	The skill tiering axis (T1–T4) defined in Section 5.2, reflecting what a skill does to data.

16. Document Control & Review History

Version	Date	Author	Change Summary
1.0	May 2025	Mathew Steele - Director, Enterprise Systems	Initial release.
1.1 (Draft)	May 2026	Jim Costigan - Enterprise AI Program Manager	Restructured around the governed AI platform. Introduced two-axis tiering (Exposure + Trust). Added Sanctioned Path Sufficiency principle and approved-component default. Split model-provider requirements into internal-platform and product-feature paths. Replaced AI Steering Committee with Forcepoint AI Council. Added platform architecture section, skill contract, and required platform telemetry.
1.1.1 (Draft)	May 2026	Jim Costigan - Enterprise AI Program Manager	Added 4.2 orchestration plane and 7.3 connector layer to align with the platform reference architecture. Added confidence-score-based HITL escalation as a required control (4.3, 9.1, 9.6). Distinguished connector skills from agentic automation (9.3). Added authenticated-path principle (2). Replaced the Confluence intake form with the AI Skills Portal (6.2). Introduced Appendix A (reference implementation, informative) and Appendix B (variance register). Updated RACI, definitions, and telemetry accordingly.

This standard is reviewed annually by the Forcepoint AI Council or upon any material change to applicable law, regulation, or Forcepoint AI strategy. Proposed revisions are submitted to the Director, Enterprise Systems and approved per Section 3.1.

Questions & Contact

For questions regarding this standard, the AI Use Case Intake process, or the AI Registry, contact Enterprise Systems at entsystems@forcepoint.com or reach out to Mathew Steele (mathew.steele@forcepoint.com).

Appendix A - Reference Implementation (Informative)

Status of this Appendix

This appendix is INFORMATIVE, not normative. It documents the current concrete implementation of the AI platform described in Section 4. Product choices may change without revising this standard; only the body of the standard sets requirements. Where the implementation extends or differs from the body, the variance is recorded in Appendix B and ratified by the AI Council.

A.1 Purpose

Section 4 defines the AI platform in capability terms - planes, gateways, registries, connectors, inspection points. This appendix maps each capability to the product currently providing it, so that engineering teams and reviewers can move from the standard to the implementation in one step. The mapping is maintained by Enterprise Systems and reviewed by the AI Council annually or on material change.

A.2 Capability-to-Product Map

Plane / Capability (Section 4.2)	Current Implementation	Role
Identity plane	Okta (corporate SSO + MFA)	Authentication boundary; in-auth identities transact with governed AI, out-of-auth identities are limited to public chatbots under Acceptable Use.
Network & access plane - user-facing portal	AI Skills Portal (VPN-protected)	Intake form, skill repository entry point, exception requests; auto-creates tracked work items in the engineering issue tracker for each submission.
Network & access plane - VPN & DLP	Corporate VPN; DLP inspection at the four points defined in 4.3	Zero-trust access and content inspection.
Model plane - LLM abstraction / routing	LiteLLM	Single API surface across approved foundation models; routing, fallback, rate limits, key rotation, structured logging.

Plane / Capability (Section 4.2)	Current Implementation	Role
Model plane - multi-model deliberation (optional)	NMAP (“multi-agent parliament”)	Multi-model deliberation/voting pattern available to confidence-sensitive use cases; itself a governed component on the approved-component list.
Orchestration plane - agent orchestration	Lang Graph (ReAct loops, tool calls)	Composes skills against a user task; emits structured traces and confidence scores.
Orchestration plane - confidence & HITL	Confidence scoring component with thresholds at 0.85 (default) and 0.95 (high-risk)	Below threshold triggers HITL escalation per 4.3, 9.1, 9.6. Thresholds are platform defaults; individual use cases may tighten them at intake.
Observability - traces & audit	LangSmith	Trace capture, evaluation runs, audit data feed for the platform telemetry dashboard.
Platform support - cache, secrets, credentials	Redis (cache) + Vault (secrets, credentials)	Performance and secret-management substrate for the orchestration and model planes.
Skill plane - runtime hosting	MCP integration platform on AWS	Hosts the gateway, orchestrator, and skill runtimes.
Skill plane - skill registry	Skills repository spanning GitHub (code + manifests), Confluence (documentation), JSON manifests, and an MCP catalog	Federated registry; the JSON manifest is the authoritative skill contract per 9.2.
Skill plane - agentic automation runtime	Sandboxed automation silo: Tines, n8n, NMAP agents	Workflow logic and security orchestration run here with no direct production-data access; enterprise-data interactions flow through the connector layer (9.3).

Plane / Capability (Section 4.2)	Current Implementation	Role
Data plane - connector layer	CData Connect (governing all data access from AI systems)	Single point of policy enforcement for source-system access (7.3); per-user delegated tokens where supported, scoped service identity otherwise.
Data plane - enterprise data sources (40+)	Salesforce, Workday, Zuora, HubSpot, FreshDesk, Jira, Databricks, M365, Okta, GitHub, and others	Systems of record reached through the connector layer.

A.3 Notes on the Implementation

- The AI Skills Portal serves a dual role: it is the 6.2 intake front door and the skill-author workbench. Submissions create tracked work items in the engineering issue tracker; the tracked item is the system of record for the intake.
- LiteLLM is the 4.2 model gateway. All internal AI traffic to foundation models flows through it; direct integrations from internal systems to model providers are prohibited without exception (7.2).
- LangGraph is the 4.2 orchestration plane. It composes skills, runs reasoning loops, and is responsible for emitting confidence scores.
- CData Connect is the 7.3 connector layer. All AI-system access to the 40+ enterprise data sources is brokered through it. Skill manifests reference data sources by their connector-layer identifiers.
- The agentic automation silo (Tines, n8n, NMAP agents) is sandboxed and has no direct production-data access; it is the 9.3 agentic automation runtime.
- Confidence-score thresholds (0.85 default / 0.95 high-risk) are platform defaults set by the AI Council under 4.3; individual use cases may tighten them at intake but not loosen them without an exception.

Appendix B - Variance Register

Purpose of this Appendix

This appendix records every place where the current implementation in Appendix A extends or differs from the body of this standard. Each variance is presented for AI Council review with a recommended disposition: ratify, condition, or remediate. Ratified variances may motivate revisions to the body at the next annual review.

B.1 Recorded Variances

#	Variance	Body Reference	Implementation (Appendix A)	Recommended Disposition
B-1	Confidence thresholds set as platform defaults (0.85 / 0.95).	4.3 requires use cases to declare a confidence threshold; sets defaults to be published by the AI Council.	Platform applies 0.85 default and 0.95 high-risk thresholds globally.	Ratify the defaults as the AI Council's 4.3 published defaults. Confirm that the high-risk category criteria are documented separately.
B-2	Multi-model deliberation ("multi-agent parliament") as an orchestration option.	4.2 model plane permits multi-model deliberation but does not require it.	NMAP is present in the platform as an optional capability for confidence-sensitive use cases.	Ratify as a permitted, governed component. Document the criteria for invoking deliberation (cost, latency, confidence) so use-case authors choose deliberately.
B-3	Separation of agentic automation from connector skills as distinct runtimes.	9.3 distinguishes the two patterns and requires sandboxing of agentic automation.	Implementation segregates them: connector skills run via CData; automation runs in Tines/n8n/NMAP silo.	Ratify. The separation is consistent with 9.3 and provides clean blast-radius boundaries.
B-4	Federated skills repository spanning GitHub, Confluence, JSON	9.2 refers to a single signed skill manifest and 15	The registry is federated across four locations.	Condition: confirm which location is authoritative for the signed manifest

#	Variance	Body Reference	Implementation (Appendix A)	Recommended Disposition
	manifests, and MCP catalog.	defines a single Skill Registry.		(recommended: JSON manifest committed to GitHub; Confluence is human-readable mirror only). Update 15 definition at next revision if needed.
B-5	Authentication boundary enforced as a binary (in-auth = governed; out-of-auth = public chatbots only).	2 and 4.3 introduce the authenticated-path principle as a control; do not specify enforcement mechanism.	Implementation enforces the binary at the Okta SSO gateway.	Ratify as the implementation of the 2 principle. Confirm that the Acceptable Use Policy explicitly addresses unauthenticated AI access.
B-6	CData as the sole connector for all enterprise data access.	7.3 requires a governed connector layer; does not require a single product.	All 40+ data sources are reached through CData.	Ratify the architectural choice. Document failover behavior for connector-layer unavailability; consider whether a second-source connector is needed for resilience.
B-7	AI Skills Portal auto-creates tracked work items in the engineering issue tracker on submission.	6.2 requires an intake form and assignment of a reviewer; does not specify tooling integration.	Portal submissions create a tracked work item automatically.	Ratify. The tracked item provides the auditable system of record for intake decisions.
B-8	AI Skills Portal is VPN-protected (not internet-reachable).	4.2 network plane requires zero-trust access;	Portal is reachable only over the corporate VPN.	Ratify. Note in 6.2 that contractors and remote employees require

#	Variance	Body Reference	Implementation (Appendix A)	Recommended Disposition
		6.2 places intake on the Portal.		VPN provisioning to submit intakes.
B-9	Observability stack named in the implementation (LangSmith); body refers to a generic observability plane.	4.2 / 10.2 require structured traces and telemetry but do not name the observability tool.	LangSmith provides trace capture and evaluation data; feeds the platform telemetry dashboard.	Ratify as the 4.2 implementation. Confirm data residency and retention align with the Records Retention Schedule.
B-10	Secrets and credentials managed by Vault; cache provided by Redis.	7.2 requires an approved secrets manager and rate-limit/quota infrastructure.	Vault is the approved secrets manager for the platform; Redis provides cache and short-lived state.	Ratify. Confirm Vault is on the Approved AI Vendor List for both internal-platform and (where relevant) product-feature use.

B.2 Review Cadence

The variance register is reviewed at every AI Council meeting where AI platform changes are proposed, and in any case no less than quarterly. Closed variances (those ratified and reflected in the next revision of the body) are moved to a historical register maintained by Enterprise Systems.